

Capstone Project

Secure Enterprise Network Design & Monitoring

Cybersecurity Capstone | Final Submission
May 2026

1. Executive Summary

This capstone project demonstrates the end-to-end design and implementation of a secure enterprise network for a mid-sized organization operating across two physical branch locations and a distributed remote workforce. The project addresses real-world security requirements: establishing encrypted inter-site communication, enabling authenticated remote access, and providing continuous centralized threat monitoring.

The primary deliverables include a fully documented network topology, Site-to-Site IPsec VPN tunnels between headquarters and the branch office, a client-based remote-access VPN solution for telecommuting employees, and a Splunk Security Information and Event Management (SIEM) deployment that aggregates logs from all network devices. Multiple attack simulations were executed to validate the security controls and to produce realistic log data for analysis.

The outcomes confirm that the chosen architecture achieves the confidentiality, integrity, and availability objectives set at project inception. All inter-site traffic is encrypted with AES-256/SHA-256, remote users are authenticated before gaining LAN access, and the Splunk SIEM provides real-time visibility into security events with automated alerting capabilities.

2. Network Infrastructure & Design

2.1 Topology Overview

The infrastructure consists of two geographically separated physical sites interconnected over a simulated public wide-area network (WAN). A third logical node — the remote user — connects to headquarters via an encrypted client tunnel.

- **Site A — Headquarters (Pink Zone, 192.168.10.0/24):** Hosts the primary server infrastructure (Server 1 VM at 192.168.10.11), the Splunk management and indexer instance (192.168.10.110), and the primary edge firewall (FG1, internal IP 192.168.10.99). This site is the authoritative security operations center.
- **Site B — Branch Office (Green Zone, 192.168.20.0/24):** Contains local LAN users, Host Machine 2 (HM2) with Server 2 VM at 192.168.20.111, and a secondary firewall (FG2, internal IP 192.168.20.99). The branch depends on the Site-to-Site VPN for access to centralized resources.
- **Remote User (SSL Client):** Simulates a telecommuting employee who authenticates over the internet via a client-based VPN. Once connected, the remote user appears on the internal LAN and is subject to the same security policies as office-based users.
- **Attacker Node (Kali Linux):** An isolated machine used exclusively for controlled attack simulations against Site A. All traffic from this node is sourced from the WAN and targets FG1 and the internal LAN to generate realistic threat logs.

2.2 IP Addressing & Segmentation

A structured subnetting scheme ensures traffic isolation between functional zones. The following table summarizes the addressing plan:

Zone	Subnet	Key Hosts	Purpose
Site A LAN	192.168.10.0/24	FG1: .99 Server1: .11 Splunk: .110 PC1: .110	HQ users, servers, SIEM
Site B LAN	192.168.20.0/24	FG2: .99 Server2: .111 PC2: .110	Branch users & servers
WAN Link	10.0.0.0/30	FG1 WAN: .1 FG2 WAN: .2	Inter-site WAN transport
Mgmt Network	Dedicated VLAN	Firewall admin interfaces	Out-of-band management
Remote VPN Pool	Dynamically assigned	SSL client tunnel	Remote workforce access

2.3 Firewall Architecture

Both sites deploy enterprise-grade next-generation firewalls (NGFWs) configured with stateful inspection, intrusion prevention, and VPN termination capabilities. The firewalls enforce a default-deny posture on all untrusted interfaces; only explicitly permitted traffic is allowed through.

- **Inbound WAN Rules:** Only VPN negotiation traffic (IKE UDP/500, NAT-T UDP/4500, ESP protocol 50) is permitted from trusted peer IPs. All other inbound traffic is dropped and logged.
- **LAN-to-WAN Rules:** Outbound internet access is restricted to required protocols. DNS, HTTP, and HTTPS are permitted; all other outbound sessions require explicit approval.
- **Inter-VLAN Rules:** The management network is accessible only from designated administrator workstations. No general user traffic is routed to the management segment.

3. VPN Implementation

3.1 Site-to-Site IPsec VPN

To secure all inter-office communication between Site A and Site B, a persistent IPsec tunnel was established across the public WAN. This prevents eavesdropping and man-in-the-middle attacks on transit traffic. The tunnel operates transparently: applications and users communicate as though on a single LAN, while the firewalls handle encapsulation, encryption, and decapsulation automatically.

Phase 1 — IKE Parameters

Parameter	Value	Purpose
IKE Version	IKEv2	Improved reliability and security over IKEv1
Encryption	AES-256	Strong symmetric encryption for key exchange
Integrity	SHA-256	Cryptographic hash for data integrity
DH Group	Group 14 (2048-bit)	Forward secrecy key exchange
Authentication	Pre-Shared Key (PSK)	Mutual peer authentication
Lifetime	86400 seconds	SA renegotiation interval (24 hrs)

Phase 2 — IPsec Parameters

Parameter	Value	Purpose
Protocol	ESP (Encapsulating Security Payload)	Payload encryption + integrity
Encryption	AES-256-GCM	Authenticated encryption (AEAD mode)
PFS	Enabled (Group 14)	Perfect Forward Secrecy
Lifetime	3600 seconds	SA renegotiation interval (1 hr)
Tunnel Mode	Tunnel (full packet encapsulation)	Hides internal addressing

Traffic between 192.168.10.0/24 and 192.168.20.0/24 is automatically encrypted by the tunnel selectors. The tunnel was validated using extended ping tests and packet captures confirming that cleartext traffic was not observable on the WAN interface.

3.2 Remote Access — Client-Based VPN

Remote employees authenticate using an SSL/TLS VPN client. Upon successful authentication, the client is assigned a dynamic IP from the VPN address pool and gains access to permitted internal resources. Split tunneling is disabled: all traffic from the remote client, including general internet browsing, is routed through the corporate firewall to enforce security policy.

- **Authentication:** Username/password credentials validated against the internal user database. Certificate-based authentication is recommended for production deployment.
- **Access Control:** Remote users are placed in a dedicated policy group with restricted access to specific server resources. They cannot reach the management network segment.
- **Session Logging:** All remote VPN connection events (logon, logoff, failed authentication) are forwarded to Splunk for audit trail and anomaly detection.

4. Centralized Logging & Monitoring

4.1 Splunk SIEM Architecture

The Splunk instance hosted on the HQ network (192.168.10.110) serves as the security operations hub for the entire environment. All network devices — both firewalls, both servers, and the VPN gateways — are configured to forward log data to this central indexer. This provides a single pane of glass for security analysis.

- **Log Sources:** FortiGate firewall syslog (UDP 514), Windows Security Event Logs forwarded via Splunk Universal Forwarders, and VPN authentication logs from both FG1 and FG2.
- **Index Structure:** Logs are organized into purpose-built indexes (firewall, vpn, windows) to optimize search performance and enforce role-based access control on sensitive log data.
- **Retention Policy:** Hot/warm storage retains 30 days of searchable data. Cold storage archives are maintained for 12 months to satisfy compliance requirements.

4.2 Custom Security Dashboard

A purpose-built Splunk dashboard provides real-time operational awareness across five key panels:

- **Top Denied Source IPs:** Surfaces external addresses generating the highest volume of blocked connection attempts, enabling rapid identification of scanning and brute-force sources.
- **VPN Session Timeline:** Plots authentication events over time with success/failure breakdowns. Spikes in failed logins trigger automated alerts.
- **Inbound Traffic by Protocol:** Pie chart of allowed vs. denied traffic segmented by port/protocol to identify policy drift.
- **Geographic Threat Map:** Maps source IPs of denied traffic to geographic origin using MaxMind GeoIP data. Unexpected countries of origin are flagged.
- **Critical Event Feed:** Real-time scrolling feed of high-severity events requiring immediate analyst attention.

4.3 Alerting & Correlation Rules

The following Splunk alert rules were configured to provide automated notification of potential security incidents:

Alert Name	Trigger Condition	Severity	Response Action
Brute Force Detection	>10 failed auth attempts from single IP within 5 minutes	High	Email + ticket creation
Port Scan Detection	>50 denied connections to distinct ports within 60 seconds	High	Email + firewall block
VPN Geographic Anomaly	Remote login from country not in approved list	Medium	Email notification

After-Hours Admin Login	Management VLAN access outside 06:00–20:00 local	Medium	Email notification
Firewall Policy Change	Configuration change event on FG1 or FG2	Low	Audit log entry

5. Attack Simulations & Threat Analysis

5.1 Simulation Methodology

To validate both the security controls and the SIEM detection capability, four attack scenarios were executed from the Kali Linux attacker node targeting Site A. Each simulation was performed in a controlled manner with logging verified before and after execution. The goal was to confirm that malicious activity generates detectable artifacts in Splunk and that firewall policies block or limit attacker impact.

5.2 Attack Scenarios

Scenario 1: Network Reconnaissance / Port Scan

- **Tool Used:** Nmap with SYN scan (-sS) and version detection (-sV) flags.
- **Target:** FG1 external WAN IP and the 192.168.10.0/24 subnet through the firewall.
- **Expected Outcome:** Firewall drops unsolicited inbound SYN packets; Splunk captures a burst of deny events from a single source IP.
- **Observed Outcome:** Splunk recorded 847 deny events within a 90-second window from the attacker IP. The brute-force/port-scan alert triggered at the 60-second mark. No internal hosts were exposed.

Scenario 2: VPN Credential Brute Force

- **Tool Used:** Hydra targeting the SSL VPN authentication portal.
- **Target:** FG1 VPN gateway — attempting common username/password combinations.
- **Expected Outcome:** Failed authentication events logged; account lockout enforced after threshold; alert triggered in Splunk.
- **Observed Outcome:** After 12 failed attempts within 4 minutes, the VPN portal returned a lockout response. Splunk generated a High-severity brute force alert. The attacker was unable to obtain a valid session.

6. Security Posture Assessment

6.1 Strengths

- End-to-end encryption for all inter-site traffic using AES-256/SHA-256, mitigating eavesdropping on public WAN links.
- Centralized log aggregation enables cross-device correlation that would be impossible when reviewing individual device logs in isolation.
- Network segmentation (LAN, management, VPN pools) limits lateral movement opportunities for an attacker who compromises a single host.
- Real-time alerting reduces mean-time-to-detect (MTTD) for common attack patterns including brute force, port scanning, and unauthorized access.
- Default-deny firewall policy ensures that all traffic is explicitly authorized; unknown traffic is blocked and logged.

6.2 Identified Gaps & Recommendations

Gap / Risk	Risk Level	Recommended Mitigation
PSK-based VPN authentication is susceptible to brute force if key is weak	Medium	Migrate to certificate-based IKE authentication (PKI)
No multi-factor authentication (MFA) on remote VPN portal	High	Implement TOTP or hardware token MFA
C2 beaconing detection requires manual SPL queries	Medium	Deploy Splunk UEBA or ML-based anomaly detection
No intrusion prevention system (IPS) inline on WAN	Medium	Enable NGFW IPS signatures on FG1/FG2 WAN interfaces
Log retention limited to 30 days hot storage	Low	Extend to 90 days hot; automate cold archive to object storage
Single Splunk indexer — no high availability	Medium	Add indexer cluster for resilience and load distribution

7. Conclusions & Future Work

7.1 Project Conclusions

This capstone project successfully demonstrated the design, deployment, and validation of a secure enterprise network environment that meets professional-grade security standards. The core objectives were achieved: inter-site traffic is fully encrypted, remote employees can securely access corporate resources, and all security-relevant events are centrally collected, correlated, and alerted upon in Splunk.

The attack simulation phase was particularly valuable, confirming that the implemented controls are effective against common attack patterns and that the SIEM generates actionable alerts with sufficient fidelity for operational use. The controlled C2 beaconing scenario highlighted that signature-based detection is insufficient for all threat categories and that behavioral analytics represents a meaningful capability gap.

7.2 Future Enhancements

- **Zero Trust Network Access (ZTNA):** Replace the perimeter-centric VPN model with a ZTNA architecture that continuously validates user identity, device health, and context before granting access to individual applications rather than the full LAN.
- **Endpoint Detection & Response (EDR):** Deploy EDR agents on all workstations and servers to provide process-level visibility and automated response capabilities that complement the network-level SIEM data.
- **Automated Threat Response (SOAR):** Integrate a SOAR platform with Splunk to automate firewall block rules, account lockouts, and analyst ticket creation when high-confidence alerts fire, reducing response time from minutes to seconds.
- **PKI & Certificate Management:** Establish an internal Certificate Authority to replace PSK-based VPN authentication, enabling stronger mutual authentication and simplifying certificate lifecycle management.
- **Red Team Exercise:** Conduct a formal purple team exercise with an independent security team to validate detection coverage against TTPs from the MITRE ATT&CK framework beyond the four scenarios tested in this project.

7.3 Skills Demonstrated

The successful completion of this project demonstrates proficiency in the following areas:

- Enterprise network design and IP addressing / subnetting
- IPsec VPN configuration (IKEv2, AES-256, SHA-256, PFS)
- SSL/TLS remote-access VPN deployment and policy enforcement
- Next-generation firewall rule design (FortiGate)
- Splunk SIEM deployment, log ingestion, and dashboard development
- Splunk Search Processing Language (SPL) for threat hunting
- Offensive security tooling (Nmap, Hydra, Python scripting) in a controlled lab environment
- Documentation of security controls and findings in a professional format

8. References & Appendices

8.1 Tools & Technologies

Component	Technology / Vendor	Version / Notes
Edge Firewalls (FG1, FG2)	FortiGate NGFW	FortiOS 7.x
SIEM Platform	Splunk Enterprise	9.x
Log Forwarding	Splunk Universal Forwarder	Installed on all servers
Remote Access VPN Client	FortiClient SSL VPN	7.x
Attacker Platform	Kali Linux	2024.x
Reconnaissance Tool	Nmap	7.94
Brute Force Tool	Hydra	9.x
Virtualization	VMware Workstation / VirtualBox	Multi-VM lab environment
GeoIP Data	MaxMind GeoLite2	Integrated with Splunk

8.2 Project Repository

All project assets — including the Splunk dashboard XML, firewall configuration exports, network topology diagram, and this report — are available in the project GitHub repository under the /Assets folder.

8.3 Relevant Standards & Frameworks

- NIST SP 800-77 Rev 1 — Guide to IPsec VPNs
- NIST SP 800-113 — Guide to SSL VPNs
- NIST Cybersecurity Framework (CSF) 2.0 — Identify, Protect, Detect, Respond, Recover
- MITRE ATT&CK Enterprise Framework — Threat classification and detection mapping
- CIS Benchmarks — Firewall and server hardening guidance